Security Exam

The exam is a written exam, individual work, without any PC / Phone / Internet / book / Course.

Duration : 1h15

Question 1: Http Basic Auth

Explain with diagrams the Http requests & responses with all their Verb+Headers+Body+Status when accessing a page http://server/page1.html, being redirected to http://server/login.html, then log-in.

Question 2: Https (TLS) Hand-Shake

Explain with diagrams the Https protocol with its 2 phases: TLS Hand-Shake, then communication between 2 points (client - server). Draw what is stored on each side, what is generated, what is transmitted (in terms of certificates, public/private keys and symmetric session keys).

Question 3: RSA

Explain RSA maths, the computing resources needed for communicating, and for attacking. Explain public/private keys and how they are used to encrypt/decrypt or sign.

Question 4: Man-in-the-middle

Draw the man-in-the-middle communications: how messages are encrypted/decrypted (in term of public/private keys) in flow Alice->Malory->Bob, then Bob->Malory->Alice.

Question 5: Web-site Certificates

Explain Web-site certificates for https trust. Link with your browser, Issuer. What is a self-signed certificate, and a certificate chain hierarchy.

Question 6: Stack Buffer Overflow

Explain stack buffer overflow vulnerabilities and remediations. Explain Canary, NX-Bit, ROP, Return-to-Libc, ASLR

Question 7: POSIX file security permissions

Explain POSIX file permissions, how they are used to deny read/write/execute for a given user/process. Give command line examples of chmod, chown, chgrp, S-bit. Compare S-bits and sudo.

Question 8: SQL Injection

Explain and give example of a SQL Injection vulnerability. How to attack, detect, remediate it.

Question 9: Network Security Equipements

Describe (with drawings) L3 Firewall, L6 Firewall, Internet Downloading Proxy, Anti-Virus, DMZ, HoneyPot, Bastion, VPN, Hub&Spoke architecture…

Question 10: Password & Credentials Managment

Give best practices a/ to manage your passwords, b/ to store end-user passwords in database, and 3/ to store credentials in deployed configuration files on servers.